CÓDIGOCLARO · RUTA REACT

Tema 15 · Seguridad y despliegue

Guía de estudio · DAM/DAW

XSS, secretos, variables de entorno y build.

1. Explicación

React escapa texto interpolado en JSX, lo que ayuda a evitar que una cadena se interprete como marcado. dangerouslySetInnerHTML omite esa protección contextual y no debe recibir contenido no confiable sin sanitización adecuada. Todo lo incluido en un bundle de navegador puede inspeccionarse; una variable de entorno del cliente no es un secreto. Mantén credenciales en el servidor, valida allí las operaciones sensibles y sigue el comando de build y despliegue de la herramienta configurada.

2. Ejemplo

Código · jsx

```jsx
function Vista({ mensaje }) {
  return <p>{mensaje}</p>;
}

export default function App() {
  return <Vista mensaje="<script>no se ejecuta</script>" />;
}
```

Resultado esperado

```
El texto se muestra literalmente en el párrafo; no se crea ni ejecuta una etiqueta script.
```

3. Errores frecuentes

- Usar dangerouslySetInnerHTML con HTML aportado por usuario sin una sanitización mantenida.
- Incluir una clave privada en variables del cliente, repositorio o bundle.
- Creer que ocultar un botón en React sustituye autorización en el servidor.

4. Ejercicio

Muestra un comentario aportado como texto y define dónde guardarías una credencial necesaria para una API privada.

Casos que debe superar

Entrada	Resultado esperado
"Hola"	Se muestra Hola como texto
"aviso"	Las etiquetas se muestran como texto y no se interpretan como HTML
Credencial de API privada	Se conserva en el servidor y no aparece en el bundle cliente

5. Solución explicada

Código · jsx

```jsx
function Comentario({ texto }) {
  return <p>{texto}</p>;
}
// La credencial privada se usa desde un endpoint de servidor, no desde el bundle React.
```

Criterio de aceptación: Se acepta una arquitectura distinta si los datos se tratan como texto o se sanitizan según contexto y el secreto no llega al navegador.

Otras soluciones válidas

- Renderizar contenido no confiable como texto dentro de JSX.
- Permitir HTML enriquecido solo tras sanitizarlo con una biblioteca mantenida como DOMPurify.

6. Fuentes oficiales

Equipo de React — Common DOM Components: dangerouslySetInnerHTML · OWASP — Cross Site Scripting Prevention Cheat Sheet · OWASP — Secrets Management Cheat Sheet